



APEX UNIVERSITY, JAIPUR

Vulnerability Assessment and Penetration Testing

Student Name : Sachin Jangir

Roll No : 23CA2591049

Programe Name : BCA (CS)

Semester : 5th

Group Project : NO

Group Code : S

Group Details :

Sachin Jangir

23CA2591049



ACKNOWLEDGEMENT

Currently, I am undertaking a detailed Vulnerability Assessment and Penetration Testing (VAPT) project in partial fulfillment of the requirements for the degree of BCA in Cyber Security at Apex University. This project involves a thorough analysis of network systems to identify and rectify potential security vulnerabilities through systematic assessment and penetration testing methodologies. By bridging the gap between theoretical concepts and practical application, this project demonstrates my technical proficiency in cybersecurity and aims to contribute to a deeper understanding of secure network architecture.



INSTRUCTIONS

In this report we have performed Vulnerability Assessment & Penetration Testing (VAPT) on Home of Acunetix Art by using various kinds of web application penetration techniques that hackers use to compromise web applications and also about how to secure them.

Hosts :

HOST : Home of Acunetix Art

SCOPE : <http://testphp.vulnweb.com/>

PORT : 80

OPERATING SYSTEM : Ubuntu

WEB SERVER : Nginx



SUMMARY OF SEVERITY ISSUE

High severity issues : 8

Medium severity issues : 7

Low severity issues : 5

Total security issues : 20

VERSION DISCLOSER

SEVERITY : LOW - RISK

CWE - 200

IMPACT :

The Server header describes the server application that handled the request. Detailed information in this header can expose the server to attackers. Using the information in this header, attackers can find vulnerabilities easier.

MITIGATION :

Configure the webserver to stop sending detailed information in the Server header.

Request	Response
PrettyRawHex POST /userinfo.php HTTP/1.1 Host: testphp.vulnweb.com User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:123.0) Gecko/20100101 Firefox/123.0 Accept: text/html,application/xhtml+xml,application/	RawHexRender 1 HTTP/1.1 200 OK 2 Server: nginx/1.19.0 3 Date: Fri, 08 Mar 2024 03:45:14 GMT 4 Content-Type: text/html; charset=UTF-8 5 Connection: close 6 X-Powered-By: PHP/5.6.40-38+ubuntu20.04.1+deb.sury.org+1



OUT-OF-DATE VERSION

CWE - 829

SEVERITY : MEDIUM - RISK

IMPACT :

Since this is an old version of the software, it may be vulnerable to attacks.

MITIGATION :

Please upgrade your installation of Nginx to the latest stable version.

Please upgrade your installation of PHP to the latest stable version.

Please upgrade your installation of MySQL to the latest stable version.



VERSIONS

NGINX :

Identified Version : 1.19.0

Latest Version : 1.25.4

PHP :

Identified Version : 5.6.40

Latest Version : 8.2.0

MYSQL :

Identified Version : 8.0

Latest Version : 8.3.0



NO SPF RECORD FOUND

CWE - 347

SEVERITY : LOW - RISK

IMPACT :

The absence of an SPF (Sender Policy Framework) record increases the risk of email spoofing, leading to potential phishing attacks, malware distribution, and deliverability issues for legitimate emails. It also jeopardizes domain reputation and compliance efforts. Implementing an SPF record is essential to authenticate emails and safeguard the integrity of the domain's communication.

MITIGATION :

There isn't one ultimate rule for adding the correct SPF Record. It highly relies on your own infrastructure, and what services you use for your various email strategies.

Our recommended strategy, of course, is to implement DMARC and start collecting detailed DMARC reports. They'll help you gain insight into your email infrastructure and with our 'Email Vendor Identification' feature, point to the sources that need proper SPF and DKIM authentication.



https://www.kitterman.com/spf/getspf3.py

SPF record lookup and validation for: <http://testphp.vulnweb.com/>

SPF records are published in DNS as TXT records.

The TXT records found for your domain are:

No valid SPF record found.

[Return to SPF checking tool \(clears form\)](#)

Use the back button on your browser to return to the SPF checking tool without clearing the form.

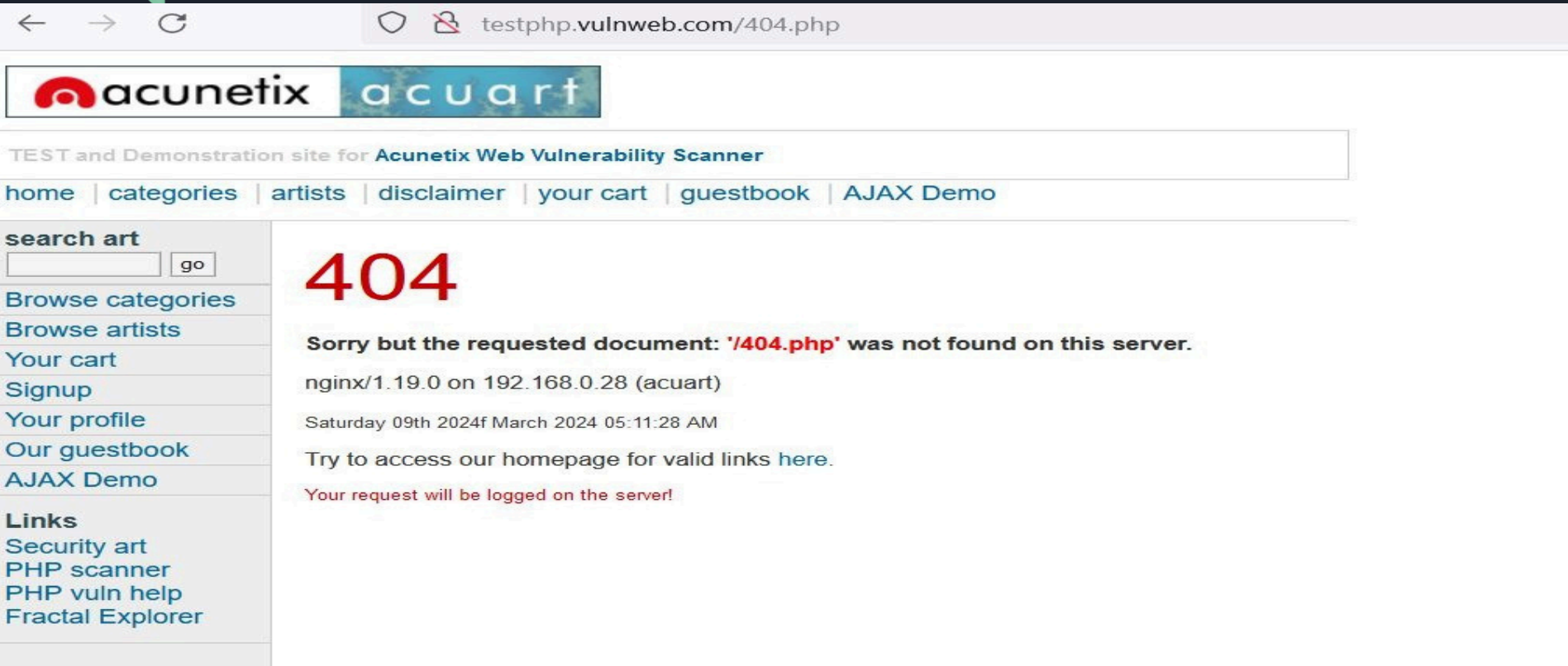
IMPROPER ERROR HANDLING

CWE - 209

IMPACT:

404 Not Found error that reveals information.

SEVERITY: LOW - RISK



The screenshot shows a web browser window with the address bar displaying `testphp.vulnweb.com/404.php`. The page header includes the 'acunetix' logo and the text 'TEST and Demonstration site for Acunetix Web Vulnerability Scanner'. A navigation menu contains links for 'home', 'categories', 'artists', 'disclaimer', 'your cart', 'guestbook', and 'AJAX Demo'. On the left, there is a sidebar with a 'search art' section, a 'Browse categories' section, and a 'Links' section. The main content area displays a large red '404' error code, followed by the message: 'Sorry but the requested document: **"/404.php"** was not found on this server.' Below this, it shows server information: 'nginx/1.19.0 on 192.168.0.28 (acuart)' and the timestamp 'Saturday 09th 2024f March 2024 05:11:28 AM'. A link is provided to access the homepage for valid links, and a note states 'Your request will be logged on the server!'.

← → ↻ testphp.vulnweb.com/404.php

acunetix acuart

TEST and Demonstration site for Acunetix Web Vulnerability Scanner

home | categories | artists | disclaimer | your cart | guestbook | AJAX Demo

search art
 go

Browse categories
Browse artists
Your cart
Signup
Your profile
Our guestbook
AJAX Demo

Links
Security art
PHP scanner
PHP vuln help
Fractal Explorer

404

Sorry but the requested document: **"/404.php"** was not found on this server.

nginx/1.19.0 on 192.168.0.28 (acuart)

Saturday 09th 2024f March 2024 05:11:28 AM

Try to access our homepage for valid links [here](#).

Your request will be logged on the server!



SSL/TLS NOT IMPLEMENTED

CWE - 311

SEVERITY : MEDIUM - RISK

IMPACT :

An attacker who is able to intercept your - or your users' - network traffic can read and modify any messages that are exchanged with your server.

That means that an attacker can see passwords in clear text, modify the appearance of your website, redirect the user to other web pages or steal session information.

Therefore no message you send to the server remains confidential.

MITIGATION :

We suggest that you implement SSL/TLS properly, for example by using the certbot tool provided by the Let's Encrypt certificate authority. It can automatically configure most modern web servers, e.g. Apache and Nginx to use SSL/TLS. Both the tool and the certificates are free and are usually installed within minutes.



WEAK PASSWORD POLICY

CWE - 521

SEVERITY : MEDIUM - RISK

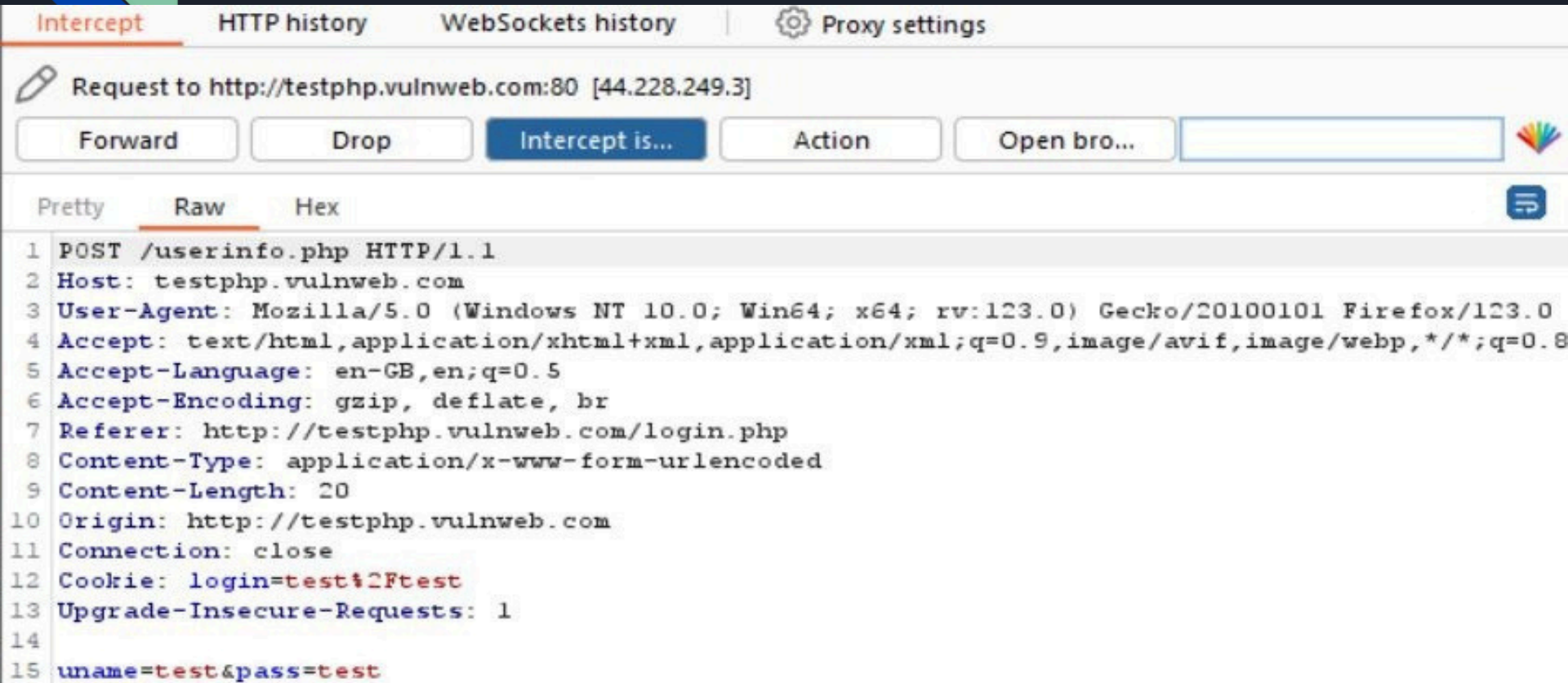
IMPACT :

Weak password policies increase the risk of users creating weak passwords that could allow attackers to steal easily through generic techniques such as brute force attacks, authentication challenge theft, etc.

MITIGATION :

To mitigate the risk of easily guessed passwords facilitating unauthorized access there are two solutions: introduce additional authentication controls (i.e. two-factor authentication) or introduce a strong password policy. The simplest and cheapest of these is the introduction of a strong password policy that ensures password length, complexity, reuse and aging; although ideally both of them should be implemented.

CLEAR TEXT PASSWORD : REQUEST INTERCEPT



Intercept HTTP history WebSockets history Proxy settings

Request to http://testphp.vulnweb.com:80 [44.228.249.3]

Forward Drop Intercept is... Action Open bro...

Pretty Raw Hex

```
1 POST /userinfo.php HTTP/1.1
2 Host: testphp.vulnweb.com
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:123.0) Gecko/20100101 Firefox/123.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
5 Accept-Language: en-GB,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://testphp.vulnweb.com/login.php
8 Content-Type: application/x-www-form-urlencoded
9 Content-Length: 20
10 Origin: http://testphp.vulnweb.com
11 Connection: close
12 Cookie: login=test%2Ftest
13 Upgrade-Insecure-Requests: 1
14
15 uname=test&pass=test
```

- 
1. PASSWORD SAME AS USER
 2. SIMPLE PASSWORD
 3. LENGTH MUST BE USED MORE THAN 6 or 8



Lack of Security Headers

CWE - 693

IMPACT :

SEVERITY : LOW - RISK

The absence of security headers on a website increases vulnerability to attacks like XSS and data injection, compromising user data and trust. This can lead to decreased traffic, reputation damage, and legal penalties for non-compliance. Additionally, search engine rankings may suffer, impacting visibility and traffic. Implementing security headers is crucial for mitigating risks, ensuring user safety, and preserving the website's integrity.

MITIGATION :

Content-Security-Policy (CSP): Implement a strict CSP policy to control the resources loaded by your website and mitigate XSS attacks. Start with a default-src directive and progressively tighten restrictions.

X-Frame-Options: Use "DENY" to prevent framing of your website or "SAMEORIGIN" to allow framing only from the same origin

X-Content-Type-Options: Set to "nosniff" to prevent browsers from MIME-sniffing responses.

Referrer-Policy: Consider setting "no-referrer" or "strict-origin-when-cross-origin" to control the information sent in the Referer header and enhance user privacy.

Permissions-Policy: This header allows you to control which browser features and APIs can be used by your website. It provides fine-grained control over features like geolocation, camera, microphone, etc.

http://testphp.vulnweb.com/

Scan

☐ Hide results ☒ Follow redirects

Summary

Site: <http://testphp.vulnweb.com/> - ([Scan again over https](#))

IP Address: 44.228.249.3

Report Time: 07 Mar 2024 16:31:08 UTC

Headers: ✗ Content-Security-Policy ✗ X-Frame-Options ✗ X-Content-Type-Options ✗ Referrer-Policy
✗ Permissions-Policy

Warning: Grade capped at A, please see warnings below.

Advanced: Ouch, you should work on your security posture immediately:

Start Now

Cookie Not Marked as HttpOnly

CWE - 16

SEVERITY : MEDIUM - RISK

IMPACT :

During a cross-site scripting attack, an attacker might easily access cookies and hijack the victim's session.

HttpOnly Attribute: When set to true, the HttpOnly attribute prevents client-side scripts from accessing cookies, thereby reducing the risk of cross-site scripting (XSS) attacks. If set to false, malicious scripts may be able to access sensitive cookie information, such as session tokens, leading to session hijacking, data theft, and other security breaches.

MITIGATION :

1. Set sensitive cookies as HttpOnly to prevent script access.
2. Use Secure attribute for cookies containing sensitive data to ensure transmission over HTTPS.
3. Regularly audit code for XSS vulnerabilities and enforce HTTPS site-wide.
4. Employ Content Security Policy (CSP) and HTTP Strict Transport Security (HSTS) headers.
5. Conduct frequent security assessments to identify and address vulnerabilities promptly.

search art

 go

Browse categories

Browse artists

Your cart

Signup

Your profile

Our guestbook

AJAX Demo

Links

Security art

PHP scanner

PHP vuln help

John Smith (test)

On this page you can visualize or edit you user information.

Name:	John Smith
Credit card number:	1234-5678-2300-9000
E-Mail:	test@email.com
Phone number:	2323345
Address:	21 street"/><script>alert(5)</script> Fexri Kenan))))) Efsane

Inspector Console Debugger Network Style Editor Performance Memory Storage Accessibility Application HackBar Cookie-Editor

Cache Storage Cookies Indexed DB Local Storage Session Storage

Name	Value	Domain	Path	Expires / Max-Age	Size	HttpOnly	Secure	SameSite	Last Accessed
login	test%2Ftest	testphp.vulnweb.com	/	Session	16	false	false	None	Thu, 07 Mar 2024 16:31:48 GMT

Filter values

login:"test%2Ftest"

Created:"Thu, 07 Mar 2024 16:31:48 GMT"

Domain:"testphp.vulnweb.com"

Expires / Max-Age:"Session"

HostOnly:true

HttpOnly:false

Last Accessed:"Thu, 07 Mar 2024 16:31:48 GMT"

Path:"/"

SameSite:"None"

Filter Output Errors Warnings Logs Info Debug CSS XHR Requests

BROKEN SESSION MANAGEMENT

CWE - 384

IMPACT :

SEVERITY : MEDIUM - RISK

1. **Unauthorized Access:** Attackers can hijack active sessions, gaining unauthorized access to user accounts and sensitive information.
2. **Data Breaches:** Broken session management contributes to data breaches, exposing personal and financial records.
3. **Identity Theft:** Compromised sessions can lead to identity theft and fraudulent activities.
4. **Loss of Trust:** Security incidents erode trust in the organization, resulting in decreased customer loyalty and reputational damage.
5. **Compliance Violations:** Non-compliance with regulations like GDPR or PCI DSS can lead to fines and legal consequences.
6. **Operational Disruption:** Security incidents disrupt business operations, causing downtime and loss of productivity.

MITIGATION :

1. Use strong, unpredictable session identifiers.
2. Set appropriate session timeout values. Enable
3. session revocation mechanisms. Always use
4. HTTPS to encrypt communications. Rotate
5. session identifiers upon authentication.

1.ACCOUNT LOCKOUT : DUE TO INACTIVITY

2.COCURRENT LOGIN : 4 BROWSERS AT A TIME

user info

home | categories | artists | disclaimer | your cart | guestbook | AJAX Demo | Logout test

search art go

Browse categories
Browse artists
Your cart
Signup
Your profile
Our guestbook
AJAX Demo

Links
Security art
PHP scanner
PHP vuln help
Frootal Evaluar

John Smith (test)

On this page you can visualize or edit you user information.

Name:

Credit card number:

E-Mail:

Phone number:

Address:

user info

home | categories | artists | disclaimer | your cart | guestbook | AJAX Demo | Logout test

search art go

Browse categories
Browse artists
Your cart
Signup
Your profile
Our guestbook
AJAX Demo

Links
Security art
PHP scanner
PHP vuln help

John Smith (test)

On this page you can visualize or edit you user information.

Name:

Credit card number:

E-Mail:

Phone number:

Address:

user info

home | categories | artists | disclaimer | your cart | guestbook | AJAX Demo | Logout test

TEST and Demonstration site for Acunetix Web Vulnerability Scanner

search art go

Browse categories
Browse artists
Your cart
Signup
Your profile
Our guestbook
AJAX Demo

Links
Security art
PHP scanner

John Smith (test)

On this page you can visualize or edit you user information.

Name:

Credit card number:

E-Mail:

Phone number:

Address:

user info

home | categories | artists | disclaimer | your cart | guestbook | AJAX Demo | Logout test

search art go

Browse categories
Browse artists
Your cart
Signup
Your profile
Our guestbook
AJAX Demo
Logout

Links
Security art
PHP scanner
PHP vuln help

John Smith (test)

On this page you can visualize or edit you user information.

Name:

Credit card number:

E-Mail:

Phone number:

Address:



BRUTE FORCE

User login page doesn't implement any form of rate limiting

CWE - 285

SEVERITY : HIGH - RISK

IMPACT :

It is very easy to exploit a lack of rate limiting to, for example, brute force a password via a login form. All the attacker has to do is to try out one by one the passwords that they have previously compiled and/or generated in a file.

MITIGATION :

Mitigating the lack of rate limiting on a login page is critical for security. Implement rate limiting, CAPTCHA, and two-factor authentication to deter brute force attacks. Set up account lockout policies and monitoring systems to detect suspicious activity. Educate users on password security and consider IP whitelisting/blacklisting. Utilize security headers for enhanced protection against attacks.

Steps To Reproduce

1. Tamper login page and send the request to Burp Intruder
2. Configure the payloads
3. Start the Burp Intruder

Filter: Showing all items

Request ^	Payload	Status code	Error	Timeout	Length	Comment
662	webmaster	302	☐	☐	258	
663	whoopsie	302	☐	☐	258	
664	test	200	☒	☐	6219	
665	www-data	302	☐	☐	258	
666	xpdb	302	☐	☐	258	
667	xpopr	302	☐	☐	258	
668	zabbix	302	☐	☐	258	
669		302	☐	☐	258	

Request

Response

Pretty

Raw

Hex

1

2

3

4

5

6

7

8

9

10

11

12

13

14

POST /userinfo.php HTTP/1.1

Host: testphp.vulnweb.com

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:123.0) Gecko/20100101 Firefox/123.0

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8

Accept-Language: en-GB,en;q=0.5

Accept-Encoding: gzip, deflate, br

Content-Type: application/x-www-form-urlencoded

Content-Length: 20

Origin: http://testphp.vulnweb.com

Connection: keep-alive

Referer: http://testphp.vulnweb.com/login.php

Upgrade-Insecure-Requests: 1

uname=test&pass=test



RESPONSE MANIPULATION

Response Manipulation leads to Account Takeover

CWE - 451

SEVERITY : HIGH - RISK

IMPACT :

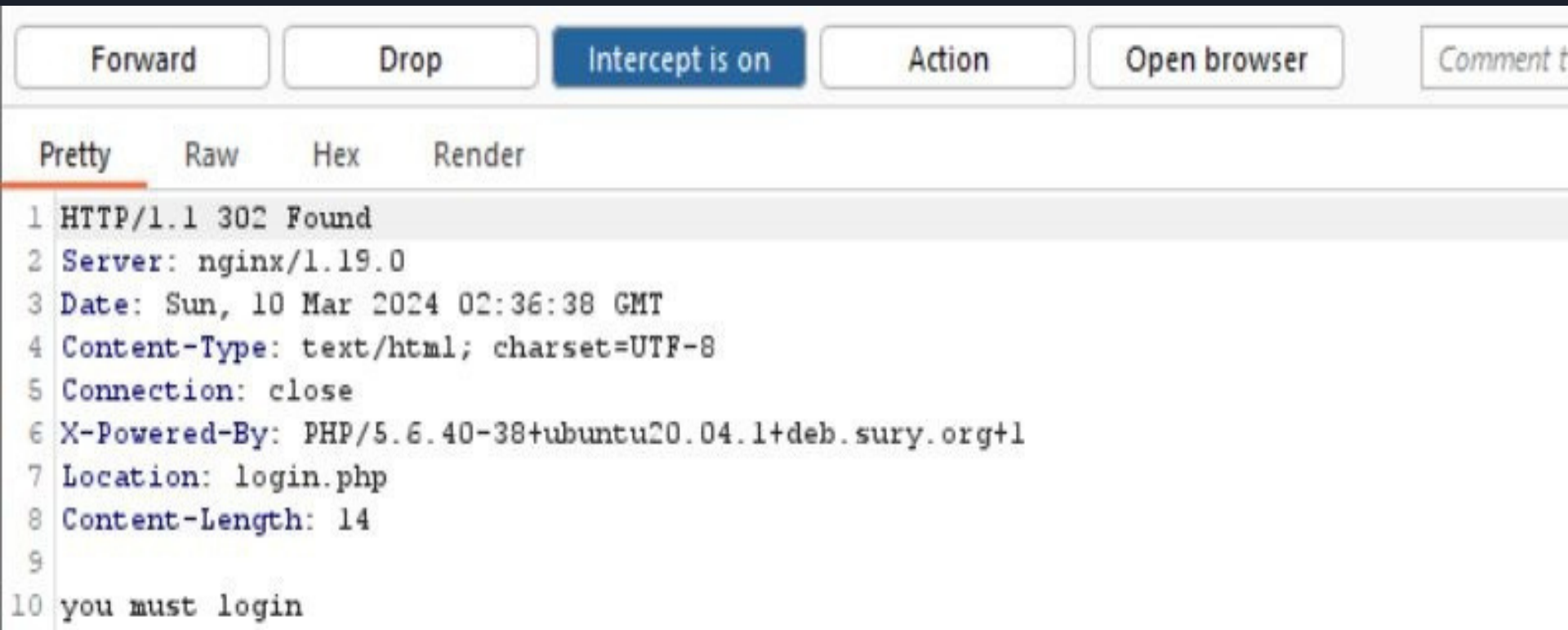
Response manipulation typically occurs during data transmission, where **attackers intercept and modify information**. Common Techniques: Attackers employ techniques like man-in-the-middle (MitM) attacks, packet injection, and content spoofing to tamper with responses

MITIGATION :

Mitigating response manipulation involves strict input validation, output encoding, and secure communication. Additionally, ensure data integrity through mechanisms like digital signatures, implement access controls, and employ security headers. Regular security audits and user education are also key to maintaining robust defense against these vulnerabilities.

STEPS TO REPRODUCE :

1. Response to this request
2. Forward the request
3. Copy the successful login response message below



The image shows a Wireshark interface with a dark theme. At the top, there is a toolbar with buttons: 'Forward', 'Drop', 'Intercept is on' (highlighted in blue), 'Action', 'Open browser', and 'Comment'. Below the toolbar, there are tabs for 'Pretty', 'Raw', 'Hex', and 'Render', with 'Pretty' selected. The main display area shows an HTTP response packet. The packet list on the left shows packet 10 selected. The packet details pane shows the following fields:

- 1 HTTP/1.1 302 Found
- 2 Server: nginx/1.19.0
- 3 Date: Sun, 10 Mar 2024 02:36:38 GMT
- 4 Content-Type: text/html; charset=UTF-8
- 5 Connection: close
- 6 X-Powered-By: PHP/5.6.40-38+ubuntu20.04.1+deb.sury.org+1
- 7 Location: login.php
- 8 Content-Length: 14
- 9
- 10 you must login

SQL INJECTION

CWE - 89

IMPACT :

SEVERITY : HIGH RISK

The impact SQL injection can have on a business is far-reaching. A successful attack may result in the unauthorized viewing of user lists, the deletion of entire tables and, in certain cases, the attacker gaining administrative rights to a database, all of which are highly detrimental to a business.

Data Leakage : Attackers can retrieve sensitive data from databases, including personally identifiable information (PII), financial records, or intellectual property, leading to breaches of confidentiality. SQL injection allows attackers to modify or delete data stored in databases, potentially causing data corruption, loss of integrity, or unauthorized changes to critical information.

MITIGATION :

To prevent SQL injection through these common attack vectors, it's crucial to implement input validation and sanitization. Prepared statements or parameterized queries should be used to ensure that user inputs are treated as data, not executable code. Proper input validation and escaping mechanisms can effectively protect web applications from these attack vectors.

DATA DUMP THROUGH SQL INJECTION

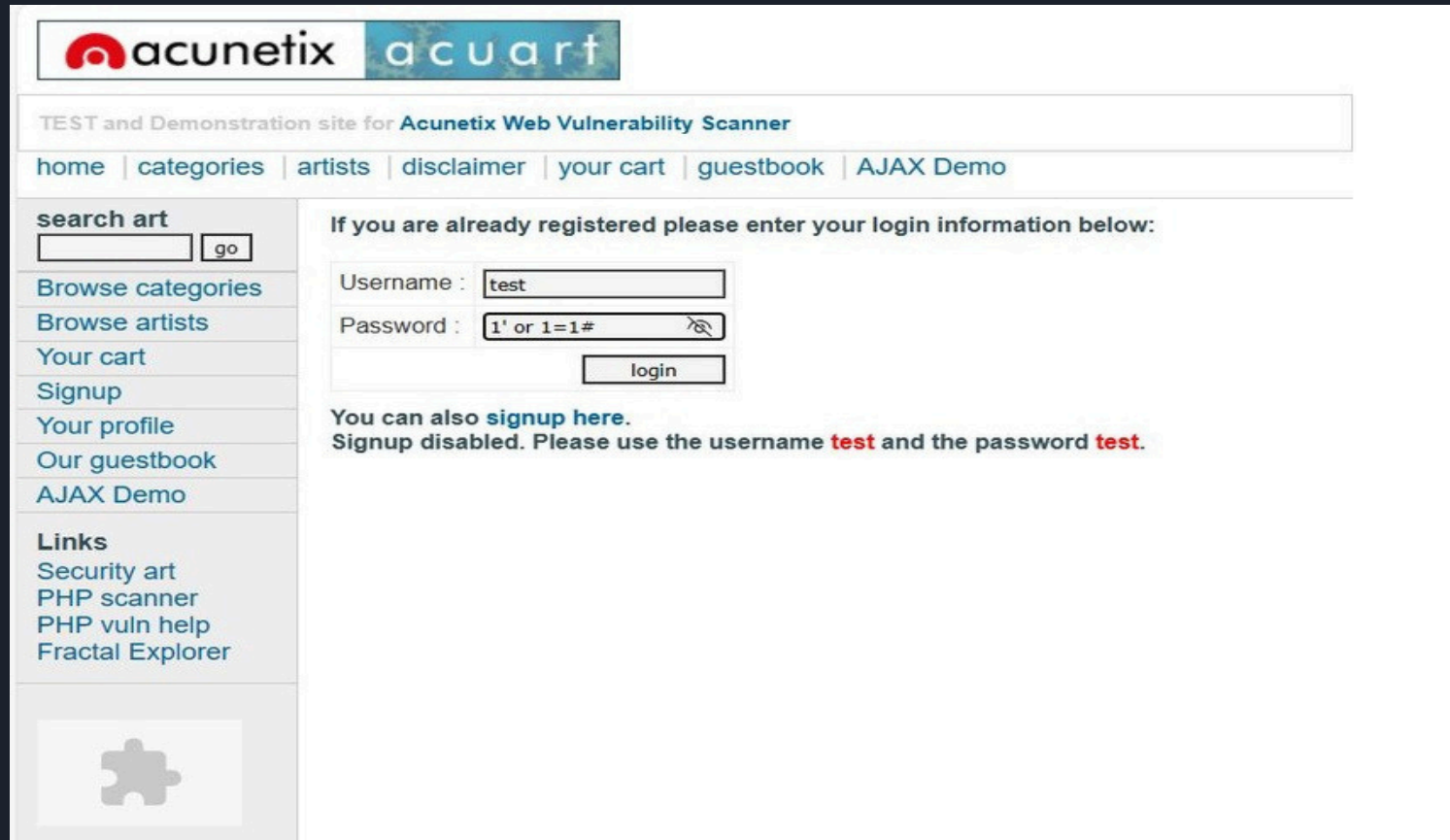
SEVERITY: HIGH - RISK

```
[04:16:47] [INFO] fetching tables for database: 'acuart'
Database: acuart
[8 tables]
+-----+
| artists |
| carts   |
| categ   |
| featured |
| guestbook |
| pictures |
| products |
| users   |
+-----+
projectdiscovery.io
+-----+
| cc | current nuclei-templates v9.7.6 are outdated. Latest is v9.7.7 |
| pass | email | phone | uname | name | address |
+-----+
| 11121123 | c4fb3373c273efb2a820a61641453cf9 | test | email@email.com | 6543432 | test | <marquee>attacker<marquee> | ".file_get_contents("http://8iplfezprw33q8plqwdedbz"."hurggj5vep.szs.prbly.win")." |
+-----+
SQL injection vulnerability has already been detected against 'testphp.vulnweb.com'. Do you want to skip further tests involving it? [Y/n] Y
Database: acuart
Table: users
[1 entry]
+-----+
| cc | current nuclei-templates v9.7.6 are outdated. Latest is v9.7.7 |
| pass | email | phone | uname | name | address |
+-----+
| 11121123 | c4fb3373c273efb2a820a61641453cf9 | test | email@email.com | 6543432 | test | <marquee>attacker<marquee> | ".file_get_contents("http://8iplfezprw33q8plqwdedbz"."hurggj5vep.szs.prbly.win")." |
+-----+
```

LOGIN PAGE BYPASS BY SQL INJECTION

QUERY : 1'OR1=1"

SEVERITY : HIGH - RISK



The screenshot shows the login page of the Acunetix Web Vulnerability Scanner. The page has a header with the Acunetix and acuart logos, a sub-header indicating it's a test site, and a navigation bar with links like home, categories, artists, disclaimer, your cart, guestbook, and AJAX Demo. On the left is a sidebar with a search bar, navigation links (Browse categories, Browse artists, Your cart, Signup, Your profile, Our guestbook, AJAX Demo), and a 'Links' section with links to Security art, PHP scanner, PHP vuln help, and Fractal Explorer. The main content area contains a login form with fields for Username and Password, and a login button. The Username field contains 'test' and the Password field contains '1' or 1=1#'. Below the form, a message states: 'You can also [signup here](#). Signup disabled. Please use the username **test** and the password **test**.'

acunetix acuart

TEST and Demonstration site for Acunetix Web Vulnerability Scanner

home | categories | artists | disclaimer | your cart | guestbook | AJAX Demo

search art

Browse categories
Browse artists
Your cart
Signup
Your profile
Our guestbook
AJAX Demo

Links
Security art
PHP scanner
PHP vuln help
Fractal Explorer

If you are already registered please enter your login information below:

Username :

Password :

You can also [signup here](#).
Signup disabled. Please use the username **test** and the password **test**.



TEST and Demonstration site for [Acunetix Web Vulnerability Scanner](#)

[home](#) | [categories](#) | [artists](#) | [disclaimer](#) | [your cart](#) | [guestbook](#) | [AJAX Demo](#) [Logout test](#)

search art

[Browse categories](#)

[Browse artists](#)

[Your cart](#)

[Signup](#)

[Your profile](#)

[Our guestbook](#)

[AJAX Demo](#)

Links

[Security art](#)

[PHP scanner](#)

[PHP vuln help](#)

[Fractal Explorer](#)

John Smith (test)

On this page you can visualize or edit you user information.

Name:	John Smith
Credit card number:	1234-5678-2300-9000
E-Mail:	test@email.com
Phone number:	2323345
Address:	New delhi
update	

You have 0 items in your cart. You visualize you cart [here](#).

Update password

Microsoft Edge will update your saved password for this site.



CROSS SITE SCRIPTING (XSS)

CWE - 79

SEVERITY : HIGH - RISK

IMPACT :

The malicious content sent to the web browser often takes the form of a segment of JavaScript, but may also include HTML, Flash, or any other type of code that the browser may execute. The variety of attacks based on XSS is almost limitless, but they commonly include transmitting private data, like cookies or other session information, to the attacker, redirecting the victim to web content controlled by the attacker, or performing other malicious operations on the user's machine under the guise of the vulnerable site.

MITIGATION :

Creating and implementing a content security policy (CSP) is an effective way of mitigating Cross-Site Scripting and other vulnerabilities. It prevents XSS by white-listing URLs from which browsers can load and execute scripts. The server prevents the client's browser from executing any script from an untrusted URL.

REFLECTED XSS

Url = [http://testphp.vulnweb.com/hpp/params.php?aaaa%2F=FUZZ&p=<script>alert\(1\)</script>](http://testphp.vulnweb.com/hpp/params.php?aaaa%2F=FUZZ&p=<script>alert(1)</script>)



testphp.vulnweb.com/hpp/params.php?aaaa%2F=FUZZ&p= <script>alert(1)</script>

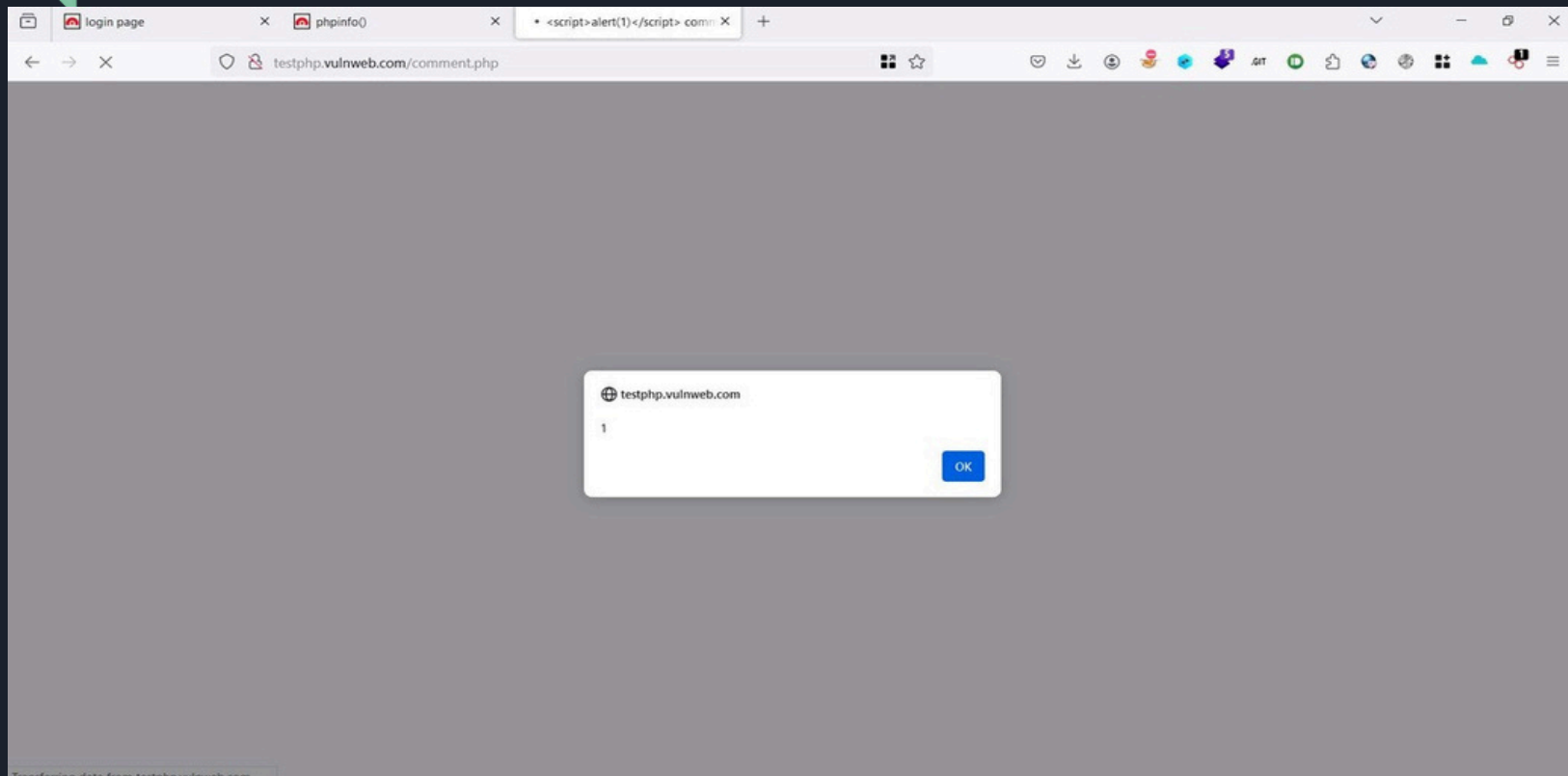


testphp.vulnweb.com

1

OK

STORED XSS IN COMMENTS FIELD



HTML INJECTION

CWE - 79

SEVERITY : HIGH - RISK

IMPACT :

HTML injection is a type of attack where malicious HTML code is inserted into a website. This can lead to a variety of issues, from **minor website defacement** to **serious data breaches**. Unlike other web vulnerabilities, HTML injection targets the markup language that forms the backbone of most websites.

MITIGATION :

Mitigating HTML injection vulnerabilities involves validating and sanitizing user inputs, implementing a strict Content Security Policy (CSP), and setting appropriate HTTP headers. Secure session management, adhering to the principle of least privilege, and conducting regular security audits are essential. By adopting these measures and conducting continuous testing, developers can effectively reduce the risk of HTML injection vulnerabilities and enhance overall application security.



testphp.vulnweb.com/search.php?test=query



TEST and Demonstration site for **Acunetix Web Vulnerability Scanner**

[home](#) | [categories](#) | [artists](#) | [disclaimer](#) | [your cart](#) | [guestbook](#) | [AJAX Demo](#)

[Logout test](#)

search art

go

[Browse categories](#)

[Browse artists](#)

[Your cart](#)

[Signup](#)

[Your profile](#)

[Our guestbook](#)

[AJAX Demo](#)

[Logout](#)

Links

[Security art](#)

[PHP scanner](#)

[PHP vuln help](#)

[Fractal Explorer](#)

searched for:

HTML Injection Find By Sachin Jangir

testphp.vulnweb.com/comment.php?aid=FUZZ

Name	<h1>HTML Injection Find By Sac
Comment	ok done
	Submit

testphp.vulnweb.com/comment.php

HTML Injection Find By Sachin Jangir
, thank you for your comment.

CLICKJACKING

CWE - 1021

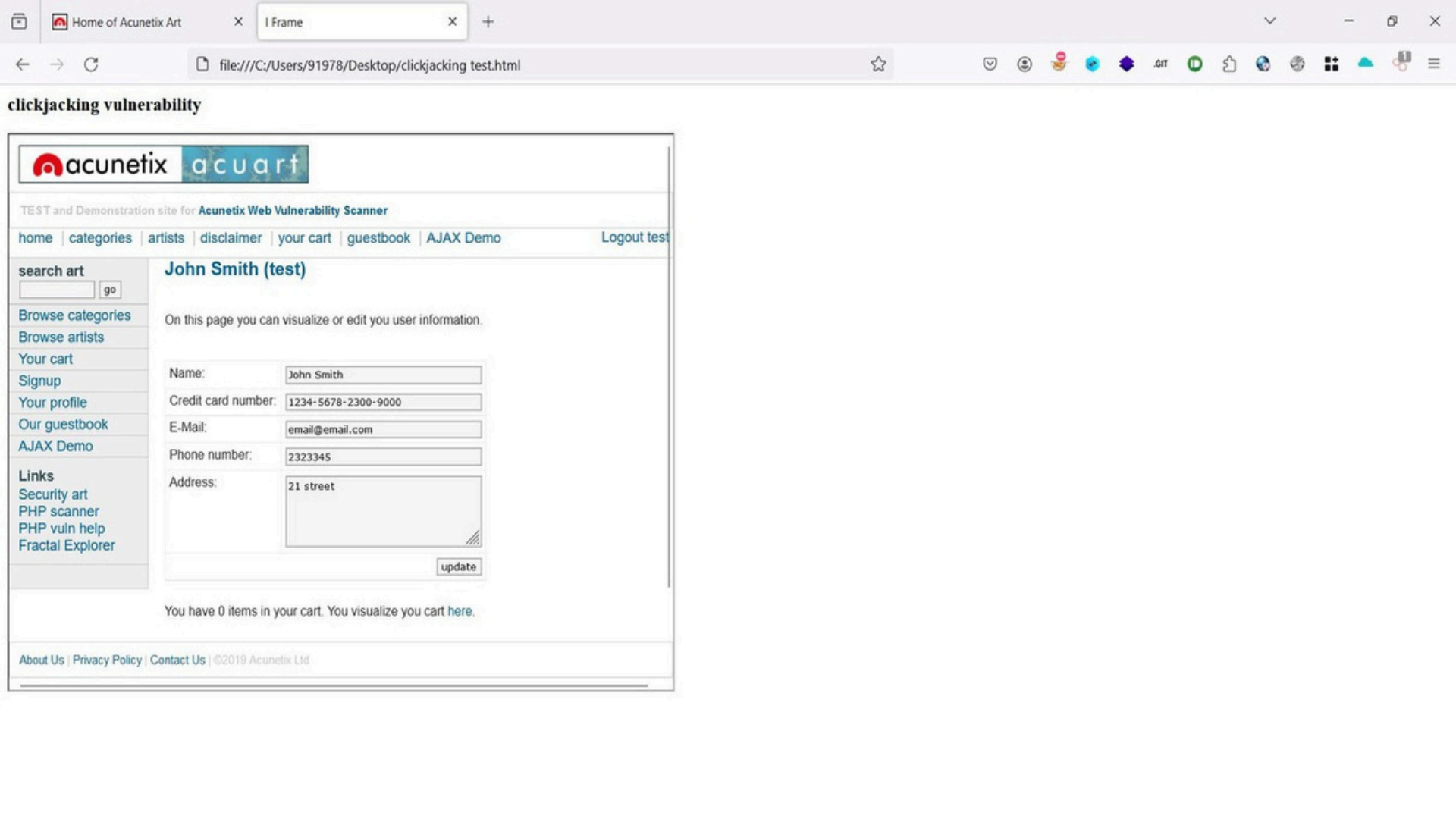
SEVERITY : MEDIUM - RISK

IMPACT :

This can cause users to unwittingly download malware, visit malicious web pages, provide credentials or sensitive information, transfer money, or purchase products online. Typically, clickjacking is performed by displaying an invisible page or HTML element, inside an iframe, on top of the page the user sees.

MITIGATION :

Mitigating CWE-1021 vulnerabilities involves implementing measures such as using frame-busting techniques, implementing proper X-Frame-Options headers, and ensuring user interface elements are not easily manipulated or obscured. By addressing these weaknesses, developers can prevent clickjacking attacks and enhance the security of their web applications.



TEXT INJECTION

CWE - 78

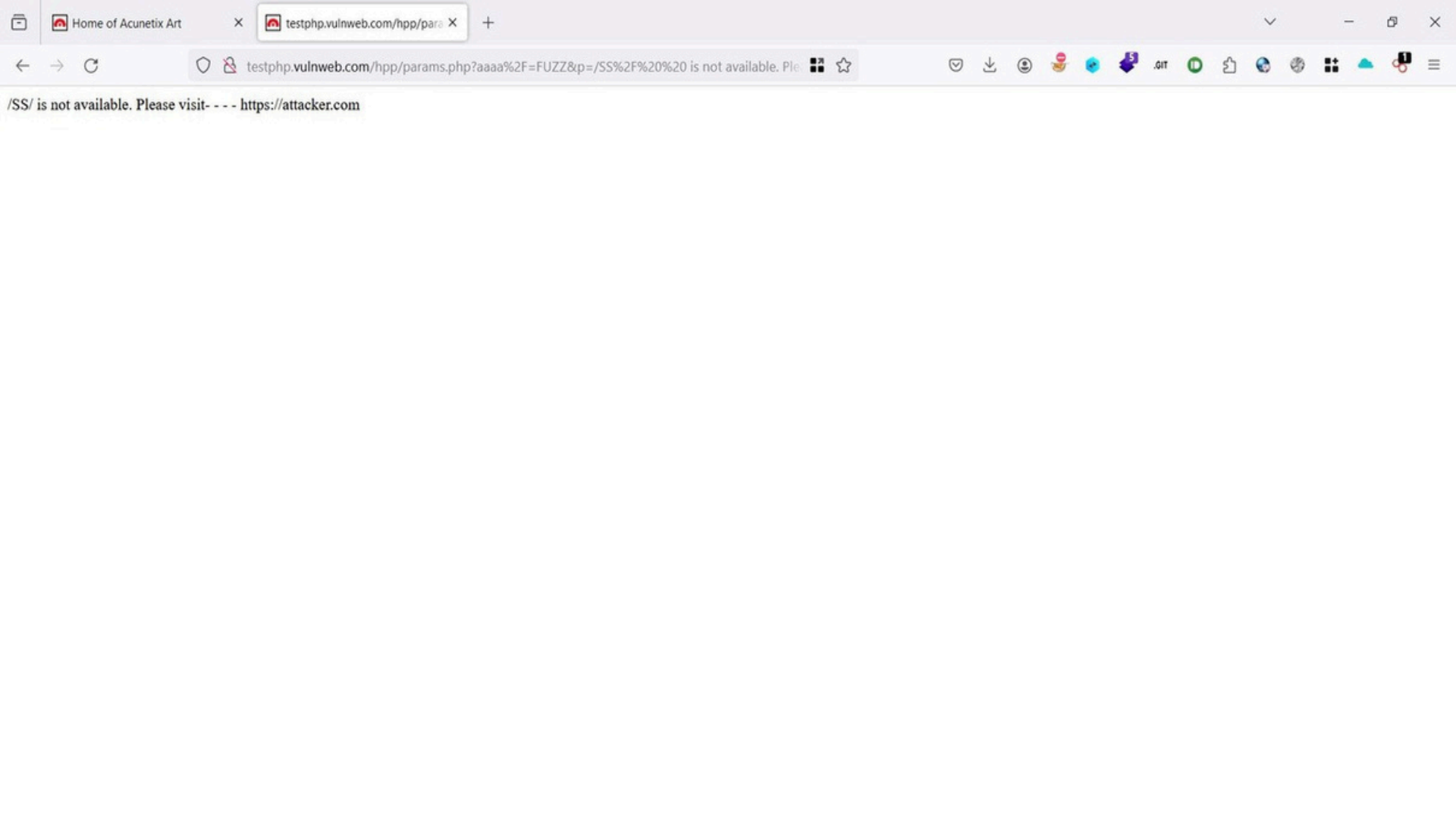
SEVERITY : LOW - RISK

IMPACT :

An attacker can use text injection vulnerability to present a customized message on the application that can phish users into believing that the message is legitimate. The intent is typical to trick victims, although sometimes the actual purpose may be to simply misrepresent the organization or an individual. This attack is typically used as, or in conjunction with, social engineering because the attack is exploiting a code-based vulnerability and a user's trust. As a side note, this attack is widely misunderstood as a kind of a bug that brings no impact.

MITIGATION :

The application should only accept the values and types that are defined for parameters and should be checked at the server-side whether there is change content, if there is change, then the application should reject that request. Also, never construct and send messages via URL in the page response. Prefer using messages predefined in a property file.





INFORMATION DISCLOSURE

CWE - 213

SEVERITY : MEDIUM - RISK

JSONFILEDISCLOSURE :

USER INFORMATION AND VERSIONS DISCLOSURE

IMPACT :

This can expose the location on the file system of the file that caused the issue along with the precise version of the server itself, and the third-party components. Attackers can use this knowledge in a variety of ways, for example, to target well-known exploits in one particular version of a component.

MITIGATION :

Remove pages from the web server.

```
    name: "Mike van Riel",
    email: "me@mikevanriel.com"
  },
  {
    name: "Jaap van Otterdijk",
    email: "account@ijaap.nl"
  }
],
description: "With this component, a library can provide support for annotations via DocBlocks or otherwise retrieve information that is embedded in a DocBlock."
},
{
  name: "phpdocumentor/type-resolver",
  version: "1.6.0",
  version_normalized: "1.6.0.0",
  source: {
    type: "git",
    url: https://github.com/phpDocumentor/TypeResolver.git,
    reference: "93ebd0014cab80c4ea9f5e297ea48672f1b87706"
  },
  dist: {
    type: "zip",
    url: https://api.github.com/repos/phpDocumentor/TypeResolver/zipball/93ebd0014cab80c4ea9f5e297ea48672f1b87706,
    reference: "93ebd0014cab80c4ea9f5e297ea48672f1b87706",
    shasum: ""
  },
  require: {
    php: "^7.2 || ^8.0",
    "phpdocumentor/reflection-common": "^2.0"
  },
  require-dev: {
    ext-tokenizer: "*",
    "psalm/phar": "^4.8"
  },
  time: "2022-01-04T19:58:01+00:00",
  type: "library",
  extra: {
    branch-alias: {
      "dev-1.x": "1.x-dev"
    }
  },
  installation-source: "dist",
  autoloader: {
    psr-4: {
      "phpDocumentor\\Reflection\\": "src"
    }
  }
}
```




TEMPLATE INJECTION

CWE - 20

SEVERITY : HIGH - RISK

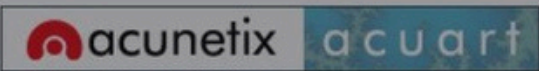
IMPACT :

This script is possibly vulnerable to Server-side template injection attacks.

Server-side template injection occurs when user-controlled input is embedded into a server-side template, allowing users to inject template directives. This allows an attacker to inject malicious template directives and possibly execute arbitrary code on the affected server.

MITIGATION :

Templates should not be created from user-controlled input. User input should be passed to the template using template parameters.



TEST and Demonstration site for Acunetix Web Vulnerability Scanner

[home](#) | [categories](#) | [artists](#) | [disclaimer](#) | [your cart](#) | [guestbook](#) | [AJAX Demo](#) [Logout test](#)

- search art
-
- [Browse categories](#)
- [Browse artists](#)
- [Your cart](#)
- [Signup](#)
- [Your profile](#)
- [Our guestbook](#)
- [AJAX Demo](#)
- [Logout](#)

- Links
- [Security art](#)
- [PHP scanner](#)
- [PHP vuln help](#)
- [Fractal Explorer](#)

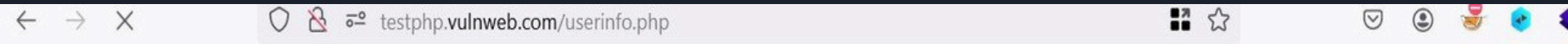
On this page you can visualize or edit you user information.

Name:	<svg onload=alert(1)>
Credit card number:	1234-5678-2300-9000
E-Mail:	email@email.com
Phone number:	2323345
Address:	21 street
update	

testphp.vulnweb.com

1

OPEN SAME PAGE WITHOUT RUN SCRIPT



testphp.vulnweb.com

1

OK



TOOLS USED

- BURP SUITE :

Application Security Testing Software

- SQLMAP :

Automatic SQL injection and database takeover tool

- NMAP :

The Network Mapper

- NIKTO :

Web server scanner

- PARAM SPIDER :

Web path discover